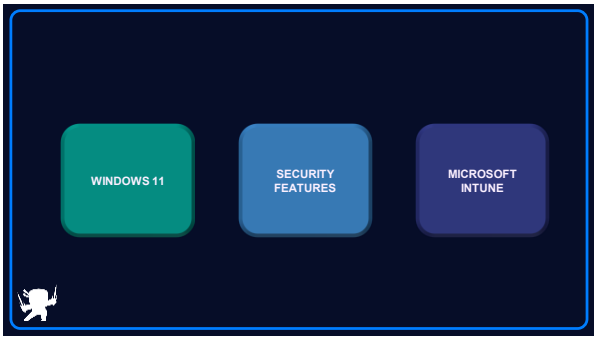
Workplace Ninja
User Group Denmark

1

WORKPLACE NINJAS
10 security settings you must configure in Windows 11
2

2

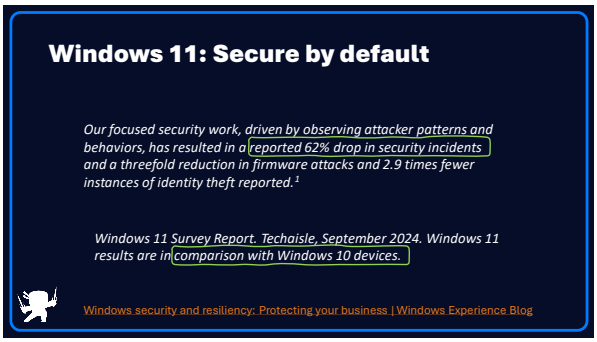
3


WINDOWS 11
SECURITY FEATURES
MICROSOFT INTUNE

4

About Nicklas
Focus
Endpoint security & management
From
Sweden
My Blog
https://rockenroll.tech
Certifications
Dual MVP (Windows & Intune)
Hobbies
Football coach for a bunch of 9-year-olds
BBQ
Contact
You will find me on most social medias

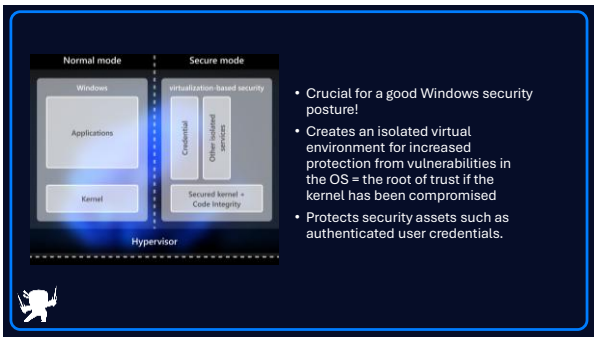
5


Windows 11: Secure by default
Our focused security work, driven by observing attacker patterns and behaviors, has resulted in a reported 62% drop in security incidents and a threefold reduction in firmware attacks and 2.9 times fewer instances of identity theft reported.[1]
Windows 11 Survey Report. Techaisle, September 2024. Windows 11 results are in comparison with Windows 10 devices.
Windows security and resiliency: Protecting your business | Windows Experience Blog

6

7

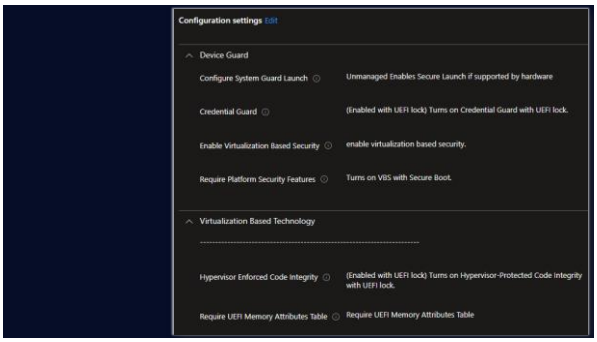
8



- Crucial for a good Windows security posture!
- Creates an isolated virtual environment for increased protection from vulnerabilities in the OS = the root of trust if the kernel has been compromised
- Protects security assets such as authenticated user credentials.

9

10



11

Hardware requirements

- 64-bit CPU
- Second Level Address Translation (SLAT)
- IOMMUs or SMMUs (Intel VT-D, AMD-Vi, Arm64 SMMUs)
- Trusted Platform Module (TPM) 2.0
- Firmware support for SMM protection
- Unified Extensible Firmware Interface (UEFI) Memory Reporting
- Secure Memory Overwrite Request (MOR) revision 2
- Memory integrity-compatible drivers
- Secure Boot

12

WORKPLACE NINJAS

#2 Local Security Authority (LSA)

13

Verifying credentials during the login process and managing authentication tokens and tickets used to enable single sign-on for services.

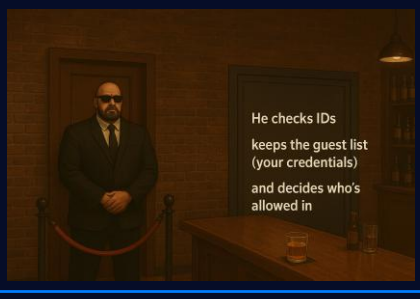
Local Security Authority protection

Helps protect user credentials by preventing unsigned drivers and plugins from loading into the Local Security Authority.

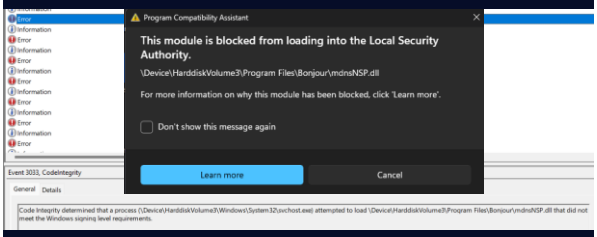
On

- LSA protection is enabled by default on all devices (MSA, Microsoft Entra joined, hybrid, and local).
- For new installs, it is enabled immediately.
- For upgrades, it is enabled after rebooting after an evaluation period of 5 days
- If LSA policy is configured by policy, it is enabled immediately

14



15



16

WORKPLACE NINJAS

3 Credential Guard

17

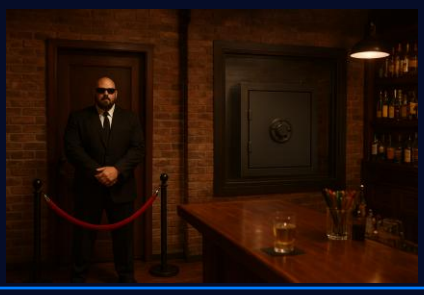
Protects against credential theft, such as pass-the-hash

- **New installations:** Enabled by default on W11 (without UEFI lock)
- **Existing installations:** No change when updating to W11
- **Controls:** Security baseline, CSP, Settings Catalog, Account protection
- **UEFI lock:** Block remote disablement (Intune/script/GPO)
- **Hardware requirements:** FW, TPM (1.2 & 2.0), VBS, Secure Boot

Note

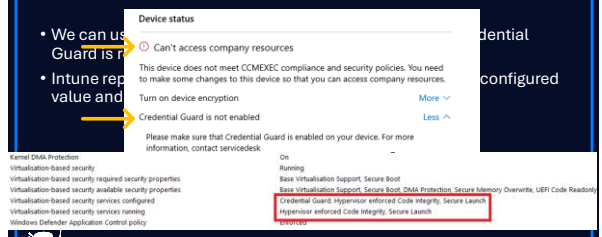
While Credential Guard is a powerful mitigation, persistent threat attacks will likely shift to new attack techniques, and you should also incorporate other security strategies and architectures.

18



19

- We can us dential Guard is r
- Intune rep configured value and



20

```
# Custom Compliance Check for Credential Guard
1 reference
function Test-CredentialGuardCompliance { ...
}

# Run the compliance check
$complianceResult = Test-CredentialGuardCompliance

# Create hash table for Intune reporting
$hash = @{
    CredentialGuardCompliant = $complianceResult.IsCompliant
    ConfigurationStatus = $complianceResult.ConfigurationStatus
    RuntimeStatus = $complianceResult.RuntimeStatus
    Timestamp = $complianceResult.Timestamp
}

# Add error information if present
if ($complianceResult.Error) {
    $hash.Error = $complianceResult.Error
}

# Return JSON for Intune
return $hash | ConvertTo-Json -Compress
```

21

JSON

```
{
    "Rules": [
        {
            "SettingName": "CredentialGuardCompliant",
            "Operator": "IsEquals",
            "DataType": "Boolean",
            "Operand": true,
            "MoreInfoUrl": "https://docs.microsoft.com/en-us/windows/security/identity-protection/credential-
guard/",
            "RemediationStrings": [
                {
                    "Language": "en_US",
                    "Title": "Credential Guard must be enabled and running. Current status: {ActualValue}.",
                    "Description": "Credential Guard provides enhanced security for domain credentials. Please
refer to the link above for configuration steps.
                }
            ]
        }
    ]
}
```

22

WORKPLACE NINJAS

#4 Windows Hello for Business Enhanced Sign-in Security

23

- ESS isolates the biometric data to trusted hardware or memory regions.
- Tamper protection!
- "Impossible" for malware to exploit the bio data to simulate a sign-in
- Utilizes VBS, so don't skip the W11 HW requirements 😊

24

Windows ~~Hello~~

Researchers Reveal "Windows Hell No" Vulnerability in Windows Hello Biometric System

August 8, 2025

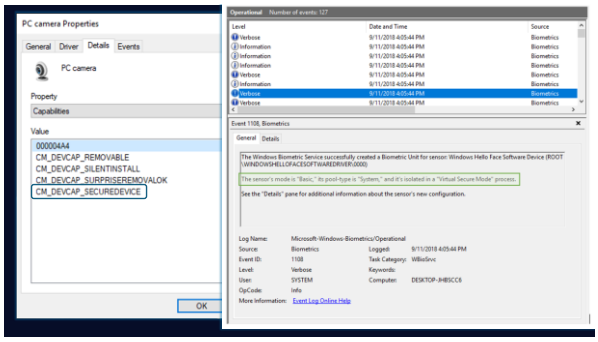
Enhanced Sign in Security to the rescue!

25

#4 Windows Hello for Business
Enhanced Sign-in Security

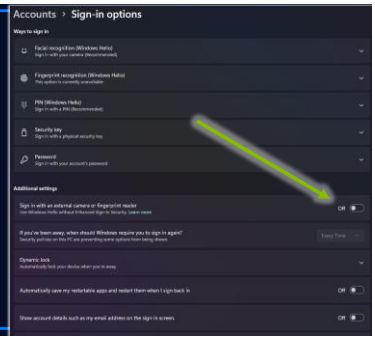
- **Prerequisites**
- ❗ All the Windows 11 hardware requirements
- 📷 Internal camera with ESS support
- 👆 Internal fingerprint sensor with ESS support
- 📄 BIOS with ESS support
- 💻 It is clear that our OEM's own the pre-reqs!

26



27

Settings ->
Accounts ->
Sign-in options



28

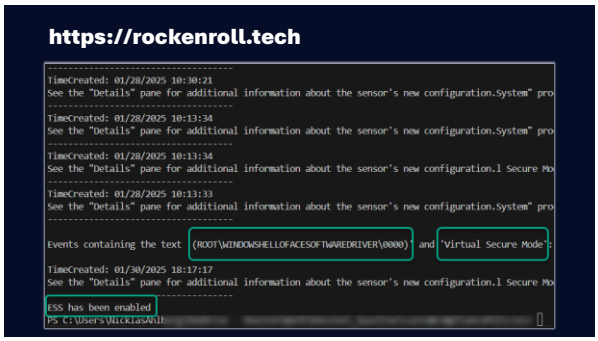
Additional settings

Sign in with an external camera or fingerprint reader
Use Windows Hello without Enhanced Sign-In Security. Learn more

29

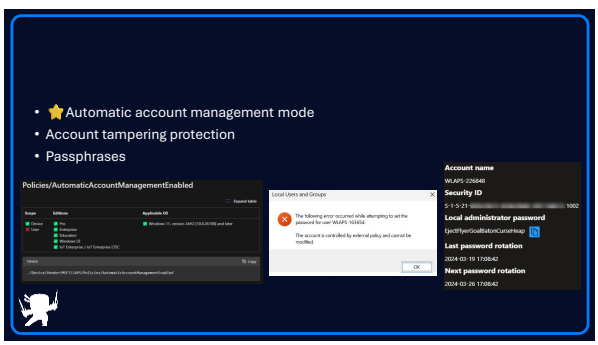
2. On devices running **Windows 11, version 24H2 or newer**: Under **Additional settings > Enhanced sign-in security**, there's a toggle that allows you to enable or disable ESS if you have relevant sensors available.
   - When the toggle is **Off**, ESS is disabled and you can use non-ESS Windows Hello compatible peripherals to sign in.
   - When the toggle is **On**, ESS is enabled and you can't use non-ESS Windows Hello compatible peripherals to sign in. Remember, you can still use external peripherals within apps like Teams when ESS is On.
   - If you have no toggle but see Enhanced sign-in security available as **set up**, the first sensor you enroll will determine your ESS state. For example, if you first enroll an ESS sensor, you will have ESS On. If you enroll a non-ESS sensor first, you will have ESS Off.
3. On devices running **Windows 11, version 23H2**: Under **Additional settings > Sign in with an external camera or fingerprint reader**, there's a toggle that allows you to enable or disable ESS:
   - When the toggle is **Off**, ESS is enabled and you may not be able to use external peripherals to sign in. Remember, you can still use external peripherals within apps like Teams
   - When the toggle is **On**, ESS is disabled and you can use Windows Hello compatible peripherals to sign in

30

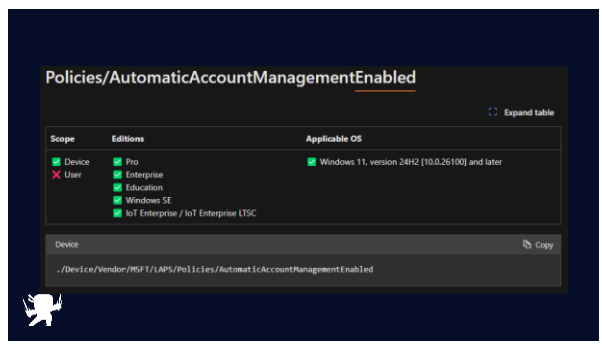


31

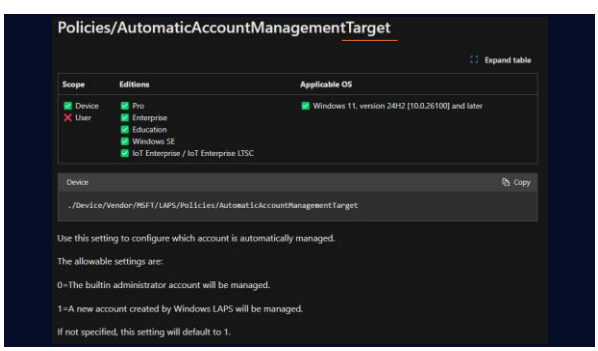
32



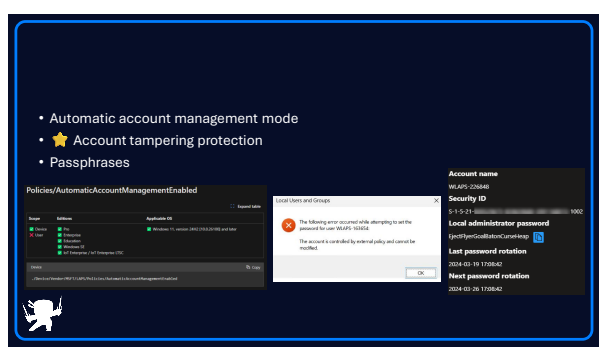
33



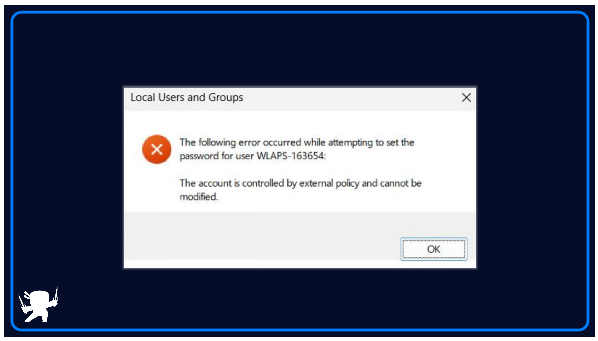
34



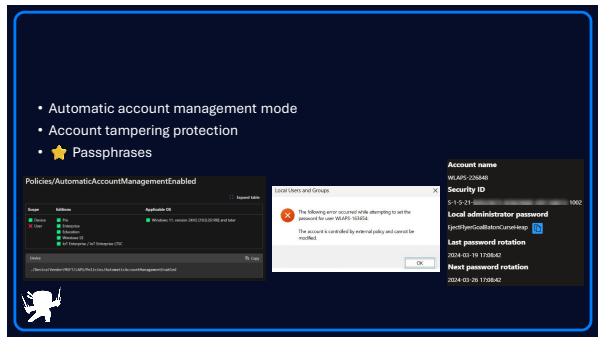
35



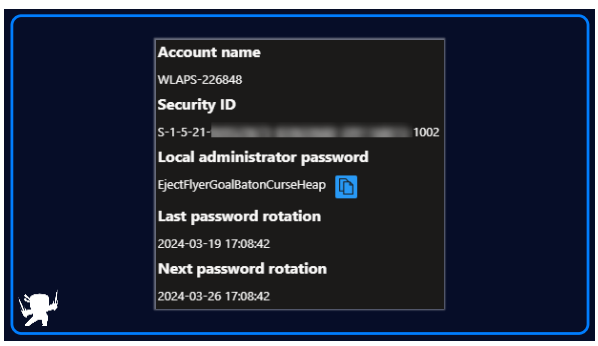
36



37



38



39

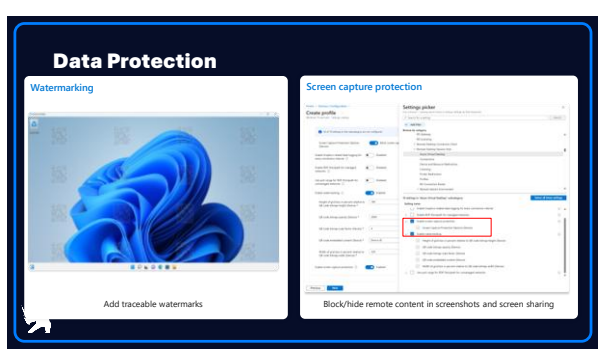
40

Device redirection for cloud PCs

Redirection	Policy
Audio input	Allow audio recording redirection
Audio output	Allow audio and video playback redirection
Cameras	Do not allow video capture redirection
Clipboard	Do not allow Clipboard redirection
COM ports	Do not allow COM port redirection
Drives	Do not allow drive redirection
Location	Do not allow location redirection
Printers	Do not allow client printer redirection
Smartcards	Do not allow smart card device redirection
USB drives	Do not allow supported Plug and Play device redirection

41

Data Protection



42

Screen capture protection (try to take a print screen)

Print screen = black screen

Screen capture protection (try to share in Teams)

Teams sharing = black screen

43

Watermarking: Good to know

Watermarking support in Windows 365

Watermarking support is configured on session hosts and enforced by the Remote Desktop client. The settings for Watermarking support can be configured via Group Policy (GPO) or the Intune Settings Catalog. The default for the QR code embedded content setting doesn't allow administrators to look up device information from leaked images for Cloud PCs.

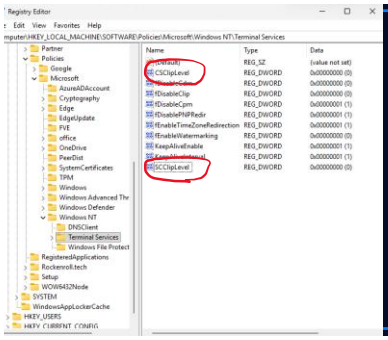
44

Device redirection for Cloud PCs

Important

- Network drives that are disconnected aren't redirected. Once the network drives are reconnected, they're not automatically redirected during the remote session. You need to disconnect and reconnect to the remote session to redirect the network drives.
- If you disable drive redirection using Intune or Group Policy, it also prevents files being transferred between the local device and remote session using the clipboard. Other content, such as text or images, isn't affected.

45



CS = Client -> Server

SC = Server -> Client

46

WORKPLACE NINJAS

#7 Personal Data Encryption (PDE)

47

- Adds an extra protection layer on personal data(AES-CBC with a 256-bit key.
- Requires Windows Hello for Business (no FIDO support)
- No support for RDP
- Backup needed! – OneDrive!?
  - TPM Reset = data is lost
  - Destructive PIN reset = data is lost

48

Personal Data Encryption (PDE) Requirements

- Windows 11 22H2 or later (automatic folder encryption 24H2)
- Hybrid Joined or Entra Joined
- Windows editions: Education/Enterprise (Pro is not supported).
- Does not replace BitLocker

49

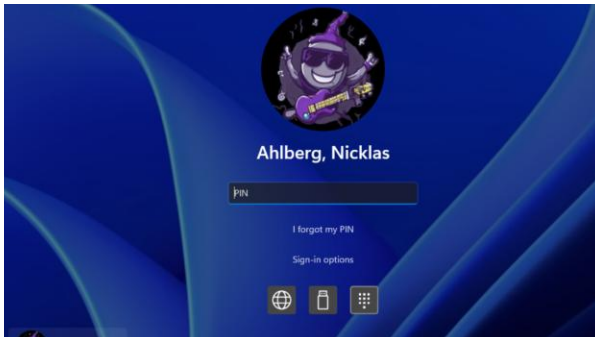
WORKPLACE NINJAS

#8 Passwordless

50

- Windows 11, version 22H2 with **KB5030310** and later
- Supports sign-in using **TAP**
- Windows 11: Sign in with auth app
- Requires **Entra ID-join** only
- More and more customers ask for passwordless!

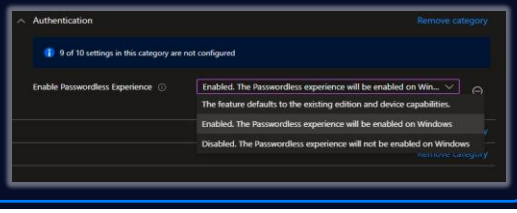
51



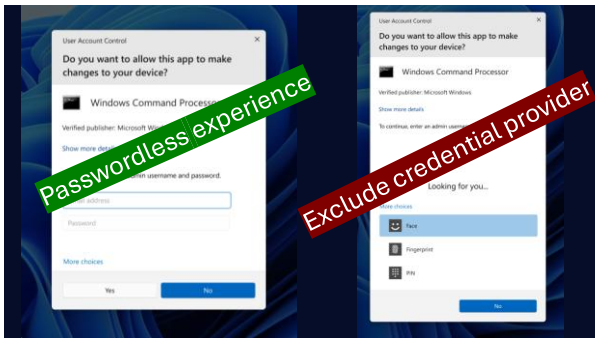
52

Passwordless experience

But, what about UAC, Windows LAPS, RDP that still require passwords?



53



54

Read the docs! - Recommendations

💡 Don't disable the password credential provider using the ***Exclude credential providers policy***.

- ***The Exclude credential providers policy*** disables passwords for all accounts, including local accounts.
- ***Windows passwordless experience*** only applies to Microsoft Entra accounts that sign in with Windows Hello or a FIDO2 security key.

💡 Exclude credential providers policy prevents the use of passwords for **RDP** and **'Run as'** authentication scenarios.

55

WORKPLACE NINJAS

#9 Enforce Windows Hello for Business

56

Enforce Windows Hello for Business

Challenge: PW-less experience will allow passwords by picking "others"

💡 Preferred credentials provider will help users to "remember" to use WHfB

57

WORKPLACE NINJAS

#10 Windows Hello for Business Multi-factor Unlock

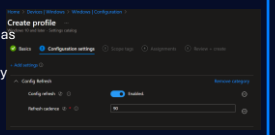
58

- Require another factor to sign in
- Shoulder surfing 👀
- Passwords and security key will not require MFU
- Supports: PIN, Facial, Fingerprint and passive (connected to a specific network or Bluetooth device)

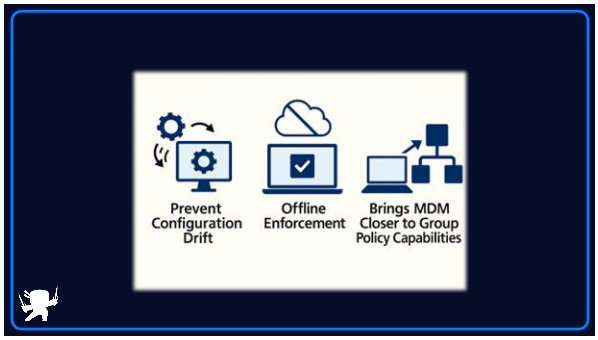
Source:

59

- A reset operation to reset any settings you manage which use the Policy CSP
- Configuration options to allow reset of managed settings to take place as frequently as every 30 minutes
- Offline functionality, not requiring connectivity to an MDM server
- Ability to pause Config Refresh for troubleshooting purposes with automatic resume after 24 hours



60



61

#11 ahhh safe from admins tampering

🤔 hmm no you are **not**

Config refresh is designed to work with MDM policies managed by the Policy CSP.

Policies like:

- Firewall
- Applocker
- Personal Device Encryption (PDE)
- Local administrative password solution (LAPS)

Is not part of drift control

62

Summary

# 1	Virtualization-based security (VBS)
# 2	Local Security Authority (LSA)
# 3	Credential Guard
# 4	WHfB: Enhanced sign-in security (ESS)
# 5	Windows LAPS
# 6	W365: Data protection
# 7	PDE
# 8	Passwordless
# 9	WHfB: Enforcement
# 10	WHfB: Multi-factor unlock
# 11	Config Refresh

63

WORKPLACE NINJAS

THANK YOU!!

Nicklas Ahlberg

64